
개인정보보호암호기술

개인정보 생명주기와 안전성 확보조치

강원대학교 이세영



이번 시간에 다룰 내용

학습목표

01

개인정보 생명주기 각 단계의 위협과 보호조치를 설명할 수 있다

02

안전성 확보조치 기준의 법적 근거와 전체 구성을 이해한다

03

접근 권한·접근통제·암호화·접속기록의 요구사항을 파악한다

04

암호화 대상 정보와 적용 지점을 정확히 구분할 수 있다

05

개인정보처리자의 규모·유형에 따른 의무 차등을 설명할 수 있다

Contents

01

개인정보 생명주기

수집 · 저장/관리 · 이용/제공 · 파기 단계별 위협과 보호조치, 흐름도

02

안전성 확보조치 기준

법적 근거, 전체 구성, 핵심 용어 정의, 안전조치의 적용 원칙

03

관리적 안전조치

내부 관리계획, 처리방침과의 구분, 위험도 분석과 영향평가

04

기술적 안전조치

접근 권한, 접근통제, 인터넷망 차단, 암호화, 접속기록, 악성프로그램

05

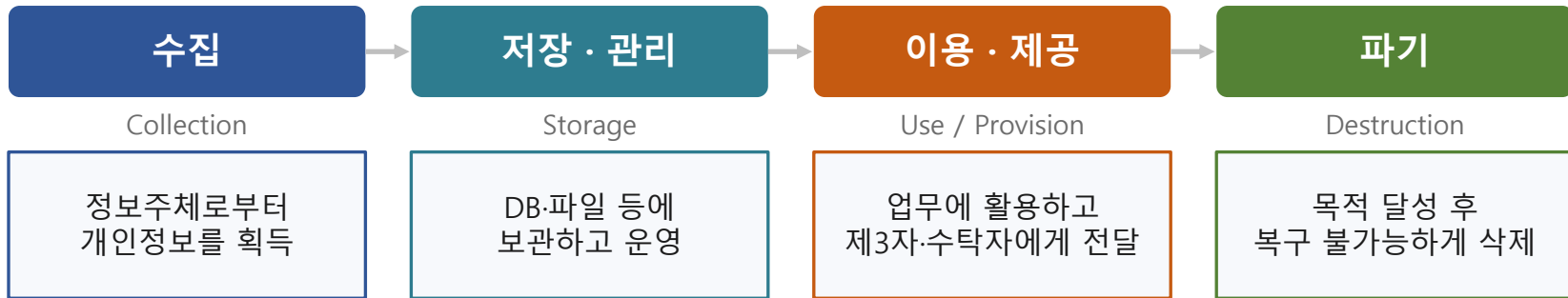
물리적 안전조치와 이행 관리

물리적 조치, 규모별 의무, 공공시스템 특례, 제재, 점검 체크리스트

개인정보 생명주기의 구조

□ 개인정보는 한 시점이 아니라 「흐름」으로 존재한다

- 각 단계마다 노출되는 위험이 다르므로, 필요한 보호조치도 달라짐



단계	핵심 원칙	대표 보호조치
수집	최소 수집 · 목적 명확화 · 적법근거 확보	전송구간 암호화, 수집 항목 최소화, 동의 이력 관리
저장 · 관리	기밀성 확보 · 접근 최소화	저장 시 암호화, 비밀번호 일방향 해시, 접근권한 통제
이용 · 제공	목적 범위 내 이용 · 추적 가능성	가명처리, 접속기록 보관·점검, 위탁 계약·감독
파기	지체 없이 · 복구 불가능하게	완전 파괴, 덮어쓰기, 암호키 파기

- 보호조치를 설계할 때는 「우리 데이터가 지금 어느 단계에 있는가」를 먼저 확인해야 함

01. 개인정보 생명주기

① 수집 단계

이 단계의 위험

- 적법근거 없이 수집 (동의 요건 미비)
- 목적에 불필요한 항목까지 과다 수집
- 입력·전송 구간에서의 도청· 가로채기
- 수집 출처가 불명확한 데이터의 유입
- 이벤트·설문 등 임시 수집 데이터의 방치

필요한 보호조치

- 수집 항목 최소화 · 필수/선택 구분
- 동의 이력(일시·항목·버전)의 기록·보관
- 전송구간 암호화 (TLS) 적용
- 입력값 검증 및 화면 마스킹 처리
- 수집 출처 고지 (법 제20조) 대응 체계

□ 수집 단계에서 결정되는 것

- 이 단계에서 수집되지 않은 정보는 이후 어느 단계에서도 유출될 수 없음
- 반대로 과다 수집된 항목은 전 생명주기에 걸쳐 보호 비용과 위험을 발생시킴
- 수집 화면의 설계가 곧 이후 모든 보호조치의 범위를 결정함

실무 점검 질문

- ① 이 항목이 없으면 서비스가 불가능한가? ② 다른 방식으로 목적을 달성할 수 없는가?
- ③ 수집 근거(조문)를 문서로 설명할 수 있는가? ④ 보유기간을 정해 두었는가?

② 저장 · 관리 단계

이 단계의 위험

- 평문 저장 → 유출 시 즉시 판독 가능
- 과도한 접근권한 부여 · 계정 공유
- 퇴사자 · 업무 변경자의 권한 미말소
- 백업본 · 개발 서버의 운영 데이터 방치
- 데이터베이스 직접 접근 통제 미흡

필요한 보호조치

- 저장 시 암호화 · 암호 키의 분리 보관
- 비밀번호는 일방향 해시 (복호화 불가)
- 최소권한 원칙 · 취급자별 계정 발급
- 권한 부여·변경·말소 내역 3년 보관
- 백업 데이터에도 동일 수준의 보호 적용

□ 저장 위치에 따른 보호 수준의 차이

저장 위치	노출 위험	요구되는 조치
인터넷망 구간 · DMZ	매우 높음	고유식별정보 저장 시 반드시 암호화
내부망 (DB 서버)	높음	암호화 저장 (주민등록번호는 예외 없음)
취급자 PC · 모바일 기기	높음	고유식별·생체인식정보 저장 시 암호화
보조저장매체 (USB 등)	매우 높음	암호화 저장 + 반출입 통제

- 유출 사고의 피해 규모는 「암호화 여부」에서 결정적으로 갈림

③ 이용 · 제공 단계

이 단계의 위험

- 수집 목적을 벗어난 이용 (목적 외 이용)
- 권한 있는 자의 조회 권한 오·남용
- 대량 다운로드 후 외부 반출
- 수탁자·재수탁자의 관리 사각지대
- 분석·AI 학습용으로 원본 데이터 유통

필요한 보호조치

- 접속기록 보관 및 정기 점검
- 다운로드 건수 제한 · 이상행위 탐지
- 출력 시 용도 특정 및 항목 최소화
- 화면·출력물 마스킹 처리
- 분석 목적에는 가명처리 데이터 사용

□ 이 단계의 특징 : 「정당한 권한을 가진 사람」이 위협 주체가 될 수 있음

- 외부 침입은 방화벽·접근통제로 막을 수 있으나, 내부자의 정상 조회는 차단할 수 없음
- 따라서 예방(차단) 중심이 아니라 「기록 · 탐지 · 사후 추적」 중심의 통제가 필요
 - 접속기록은 사고 발생 후가 아니라 발생 전에 「억지력」으로 작동하는 통제 수단
- 국내 대형 유출 사고의 상당수가 위탁·수탁 관리 사각지대에서 발생

권한을 「줄 것인가」보다 「기록하고 점검할 수 있는가」가 실제 통제력을 결정한다

④ 파기 단계

□ 보유기간이 지나거나 처리 목적이 달성된 경우 지체 없이 파기 (법 제21조)

- 「복구 또는 재생되지 아니하도록」 조치해야 하며, 단순 삭제로는 불충분

□ 안전성 확보조치 기준 제13조 : 파기 방법

구분	방법	설명
전체 파기	① 완전 파괴	소각, 파쇄 등으로 매체 자체를 물리적으로 파괴
	② 전용 소자장비 이용	디가우저 등으로 자기장을 가해 데이터를 삭제
	③ 초기화 또는 덮어쓰기	데이터가 복원되지 않도록 반복 기록·초기화 수행
일부 파기	전자적 파일 형태	해당 부분을 삭제한 후 복구·재생되지 않도록 관리·감독
	인쇄물 · 서면 등	마스킹, 천공 등으로 해당 부분을 삭제

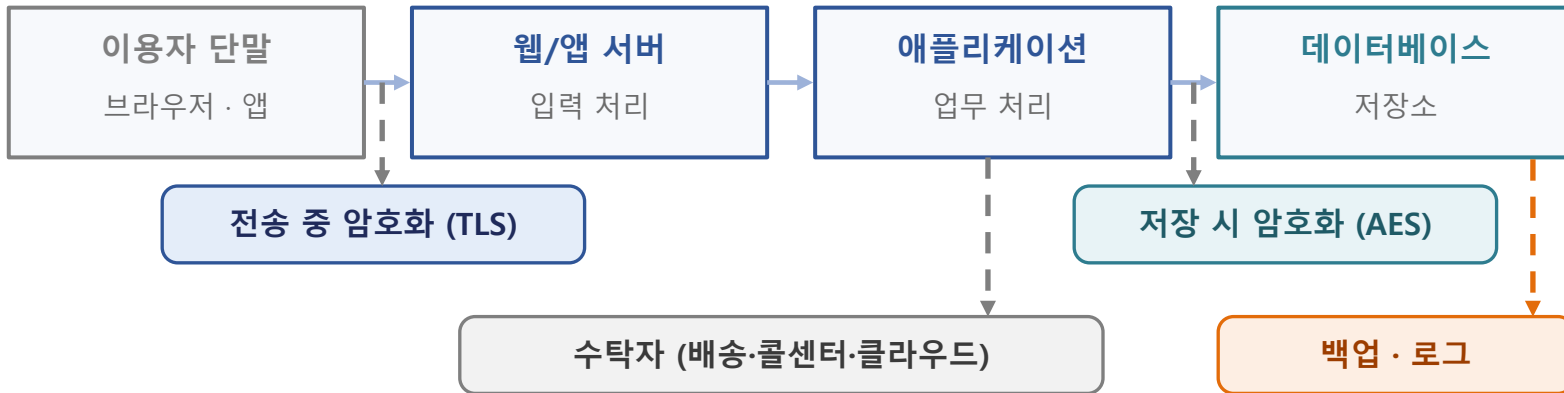
□ 실무에서 놓치기 쉬운 파기 대상

- 백업본 · 로그 · 캐시 · 개발/테스트 환경의 복제본
- 클라우드·분산 저장 환경에서는 물리적 삭제 확인이 어려움
→ 암호키 파기(크립토 셰딩) 활용
- 다른 법령에 따라 보존해야 하는 정보는 분리하여 저장·관리 (법 제21조③)

개인정보 흐름도의 작성

□ 보호조치는 「어디에 무엇이 있는지」를 알아야 설계할 수 있음

- 개인정보 흐름도 : 수집 지점부터 파기까지의 이동 경로와 저장 지점을 도식화한 문서



□ 흐름도에 반드시 표기해야 할 요소

- ① 수집 지점과 항목
- ② 전송 경로와 암호화 여부
- ③ 저장 지점과 암호화 여부
- ④ 접근 주체와 권한
- ⑤ 외부 전달(제공·위탁) 경로
- ⑥ 백업·로그의 위치
- ⑦ 파기 시점과 방법

- 흐름도가 없으면 「우리가 무엇을 보호하지 못하고 있는지」조차 알 수 없음

기준의 법적 근거

개인정보 보호법 제29조 (안전조치의무)

개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록의 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

법률	개인정보 보호법 제29조
시행령	제16조②(파기방법), 제30조(안전성 확보 조치), 제30조의2(공공시스템 운영기관 등)
고시	개인정보의 안전성 확보조치 기준 (개인정보보호위원회 고시)
안내서	개인정보의 안전성 확보조치 기준 안내서 (조문 해설 · 실무 예시 · FAQ)

구분	내용
적용 대상	개인정보처리자 / 개인정보를 제공받은 자 / 처리를 위탁받은 자(수탁자 등)
성격	반드시 준수해야 하는 「최소한의 기준」 — 상황에 따라 추가 조치가 필요할 수 있음

기준의 전체 구성

장	조문	제목	분류
제1장 총칙	제1조 ~ 제3조	목적 / 정의 / 안전조치의 적용 원칙	공통
제2장 안전성 확보조치	제4조	내부 관리계획의 수립·시행 및 점검	관리적
	제5조 ~ 제6조의2	접근 권한의 관리 / 접근통제 / 인터넷망 차단 조치	기술적
	제7조	개인정보의 암호화	기술적
	제8조 ~ 제9조	접속기록의 보관 및 점검 / 악성프로그램 등 방지	기술적
	제10조 ~ 제12조	물리적 안전조치 / 재해·재난 대비 / 출력·복사시 조치	물리적
	제13조	개인정보의 파기	공통
제3장 공공시스템	제14조 ~ 제17조	공공시스템운영기관의 안전조치 특례	특례

- 암호기술이 법적 의무로 등장하는 조문 : 제7조(암호화), 제5조·제6조(인증수단), 제8조(접속기록 보호)

제2조 : 기준이 정의하는 핵심 용어

- 조문을 정확히 읽으려면 기준이 스스로 정의한 용어를 먼저 확인해야 함

용어	정의 (요약)	실무상 유의점
개인정보 처리시스템	데이터베이스시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템	DB 자체, 웹서버·WAS, FTP·백업서버, 클라우드 서비스 포함
접속기록	접속하여 수행한 업무내역에 대하여 식별자, 접속일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 등을 기록한 것	「접속」은 데이터 송·수신이 가능한 상태를 의미
내부망	인터넷망 차단, 접근 통제시스템 등에 의해 인터넷 구간에서의 접근이 통제 또는 차단되는 구간	암호화 요구 수준을 가르는 핵심 기준
인증정보	접속을 요청하는 자의 신원을 검증하는 데 사용되는 정보	비밀번호·생체인식정보 외에 접근토큰 등도 해당
생체정보 / 생체인식정보	생체정보 중 특정 개인을 인증 또는 식별할 목적으로 처리되는 것이 생체인식정보	암호화 의무 대상은 「생체인식정보」
위험도 분석	위험요소를 식별·평가하고 통제 방안 마련을 위해 종합적으로 분석하는 행위	내부망 고유식별정보 암호화 여부 판단의 근거

- 보조저장매체 : 이동형 HDD · USB 메모리 등 쉽게 연결·분리할 수 있는 저장매체 (제7조⑤·제10조 대상)

기술적 · 관리적 · 물리적 안전조치

기술적 안전조치	관리적 안전조치	물리적 안전조치
시스템과 데이터에 직접 적용	사람과 절차에 적용	공간과 매체에 적용
· 접근 권한의 관리 (제5조) · 접근통제 · 인터넷망 차단 (제6조, 제6조의2) · 개인정보의 암호화 (제7조) · 접속기록의 보관 및 점검 (제8조) · 악성프로그램 등 방지 (제9조)	· 내부 관리계획 수립·시행 (제4조) · 개인정보 보호 조직 구성·운영 · 개인정보취급자 교육 (정기) · 이행 실태 연 1회 이상 점검 · 수탁자에 대한 관리·감독	· 전산실·자료보관실 출입통제 (제10조) · 서류·보조저장매체 잠금 보관 · 보조저장매체 반출·입 통제 · 재해·재난 대비 (제11조) · 출력·복사시 안전조치 (제12조)

□ 세 축은 서로를 대체할 수 없음

- 암호화를 적용해도 키를 아무나 볼 수 있으면 무력화
→ 접근통제(기술) + 권한관리 절차(관리) 필요
- 접근통제를 아무리 강화해도 출력물이 방치되면 유출
→ 물리적 조치가 함께 있어야 함
- 고시가 세 축을 모두 규정하는 이유 :
어느 한 축의 공백이 전체 보호 수준을 결정하기 때문

제3조 : 안전조치의 적용 원칙

제3조(안전조치의 적용 원칙) 개인정보처리자는 처리하는 개인정보의 보유 수, 유형 및 정보주체에게 미치는 영향 등을 고려하여 스스로의 환경에 맞는 개인정보의 안전성 확보에 필요한 조치를 적용하여야 한다.

□ 고려해야 할 세 가지 요소

보유 수	유형	정보주체에게 미치는 영향
처리하는 정보주체의 수 (1만 · 5만 · 10만 · 100만 등 규모별 의무 차등의 기준)	일반 개인정보 / 고유식별정보 / 민감정보 / 생체인식정보 등 정보의 성격과 민감도	유출 시 발생할 피해의 크기 (금전 피해 · 차별 · 낙인 · 회복 가능성)

□ 이 조문이 의미하는 것

- ① 획일적 적용이 아니라 「위험 비례」 적용 — 조직의 환경에 맞게 스스로 판단
- ② 다만 「스스로 판단」은 재량이 아니라 「입증 책임」을 뜻함
 - 판단 근거(위험도 분석 결과, 내부 관리계획)를 문서로 남겨야 함
- ③ 기준에 명시된 최소 조치는 판단의 대상이 아니라 반드시 이행해야 하는 의무

제4조 : 내부 관리계획의 수립 · 시행

- 개인정보처리자는 내부 의사결정 절차를 통해 내부 관리계획을 수립·시행해야 함
- 예외 : 1만명 미만 정보주체를 처리하는 소상공인·개인·단체는 생략 가능
 - 생략하는 경우에도 그 외의 안전조치 의무는 모두 이행해야 함

□ 포함되어야 할 주요 사항 (제4조① 각 호)

1. 개인정보 보호 조직의 구성 및 운영	2. 개인정보 보호책임자의 자격요건 및 지정	3. 보호책임자·취급자의 역할 및 책임
4. 취급자에 대한 관리·감독 및 교육	5. 접근 권한의 관리	6. 접근통제
7. 개인정보의 암호화 조치	8. 접속기록 보관 및 점검	9. 악성프로그램 등 방지
10. 유출·도난 방지 취약점 점검	11. 물리적 안전조치	12. 출력·복사시 안전조치
13. 개인정보의 파기	14. 유출사고 대응 계획 수립·시행	15. 위험 분석 및 관리
16. 수탁자에 대한 관리 및 감독	17. 내부 관리계획의 수립·변경·승인	18. 그 밖에 보호를 위하여 필요한 사항

- 교육 (제4조②) : 교육목적·대상, 내용, 일정·방법을 정하여 사업규모·보유 수 등에 따라 차등 실시
- 이행 실태 점검 (제4조④) : 보호책임자가 접근 권한 관리·접속기록 점검·암호화 조치 등을 연 1회 이상 점검

03. 관리적 안전조치

내부 관리계획과 개인정보 처리방침

□ 두 문서는 이름이 비슷하지만 목적 · 대상 · 근거가 모두 다름

구분	내부 관리계획	개인정보 처리방침
근거	법 제29조 (안전조치의무) 안전성 확보조치 기준 제4조	법 제30조 (처리방침의 수립 및 공개)
목적	개인정보를 안전하게 처리하기 위한 조직 내부의 실행 기준	개인정보 처리에 관한 사항을 정보주체에게 알리는 것
대상 독자	조직 내부 (임직원·취급자·수탁자)	외부 (정보주체·일반 공중)
공개 여부	내부 문서 (공개 대상 아님)	홈페이지 등에 공개 (의무)
주요 내용	보호 조직, 권한 관리, 암호화, 접속기록 점검, 교육, 위험 분석 등	처리 목적·항목·기간, 제3자 제공, 위탁, 권리 행사 방법, 보호책임자 등
승인 · 관리	최고경영층 승인, 변경 시 수정 이력 관리	수립·변경 시 공개 및 통지

- 두 문서는 서로 모순되지 않아야 함
 - 처리방침에 공개한 안전조치가 내부 관리계획에 실제로 반영되어 있어야 함

위험도 분석과 개인정보 영향평가

구분	위험도 분석	개인정보 영향평가 (PIA)
근거	안전성 확보조치 기준 제2조 정의 · 제7조③ 등	개인정보 보호법 제33조
목적	내부망 고유식별정보의 암호화 적용 여부·범위 결정	시스템 구축·변경 시 침해 위험 사전 평가
대상	개인정보파일 단위로 분석	일정 요건에 해당하는 공공기관의 개인정보파일 (의무)
수행 시점	운영 환경 변경 시 지속적으로 실시	구축·운용·변경 「전」에 실시
결과 활용	결과보고서를 작성·결재·보관 (판단 근거의 입증 자료)	개선사항 반영, 보호위원회 제출

□ 위험도 분석의 실무 포인트

- 점검 항목은 정책 기반 · 네트워크 기반 · DB/애플리케이션 기반으로 구성
 - 예) 보호책임자 지정 여부, 비인가 IP 접근 통제, DB 접속기록 기록 여부 등
- **하나라도 「아니요」이면 암호화에 상응하는 안전조치가 이루어졌다고 보기 어려움**
- 체크 결과에 대한 증적(조직도, 정책 문서, 점검 기록)을 반드시 첨부
- 위탁하여 관리하는 경우에도 위탁기관의 책임으로 작성

제5조 : 접근 권한의 관리

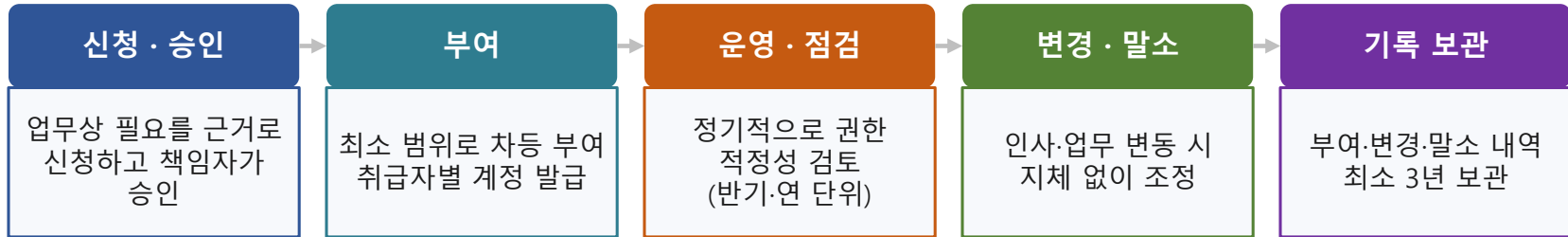
①	최소 권한 차등 부여	개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여
②	지체 없는 변경·말소	취급자 또는 취급자의 업무가 변경된 경우 지체 없이 접근 권한을 변경 또는 말소
③	권한 이력 3년 보관	권한 부여·변경·말소 내역을 기록하고 최소 3년간 보관
④	취급자별 계정 발급	정당한 사유가 없는 한 취급자별로 계정을 발급하고 다른 취급자와 공유되지 않도록 함
⑤	인증수단의 안전한 관리	취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리 (비밀번호·OTP·생체·전자서명 등)
⑥	인증 실패 시 접근 제한	일정 횟수 이상 인증에 실패한 경우 접근을 제한하는 등 필요한 조치

- 계정 공유가 금지되는 이유 : 공유 계정은 접속기록을 남겨도 「누가」를 특정할 수 없어 책임 추적성이 붕괴됨
- 기술적으로 개별 발급이 불가능한 고정 계정(root 등)은 계정 관리 대장·접근제어 시스템으로 보완 통제

04. 기술적 안전조치

접근 권한 관리의 실무

□ 계정 · 권한의 생애주기 관리



자주 지적되는 미이행 사례	문제점	개선 방향
퇴사자 계정 미삭제	퇴사 후에도 시스템 접근 가능	인사 시스템과 계정 시스템 연동
공용 계정 사용	행위 주체 특정 불가	취급자별 계정 발급, 불가피 시 사유 기록
과도한 권한 부여	업무 범위를 넘는 조회 가능	역할 기반 권한(RBAC) 설계, 정기 검토
권한 이력 미보관	사고 시 권한 변경 시점 확인 불가	권한 변경 로그 자동 기록·보관
개발자의 운영 DB 접근	실데이터 상시 노출	운영·개발 분리, 승인 기반 임시 권한

- 인증수단의 안전성 : 비밀번호 단독보다 다중 인증(MFA) · 인증서 · 일회용 비밀번호 적용이 요구되는 추세

제6조 : 접근통제

①	불법 접근 · 침해사고 방지	• IP 주소 등으로 접속 권한을 제한하여 인가받지 않은 접근을 차단 • 접속한 IP 주소 등을 분석하여 개인정보 유출 시도를 탐지하고 대응
②	외부 접속 시 안전한 인증수단	• 정당한 접근 권한을 가진 자가 정보통신망을 통해 외부에서 접속하는 경우 인증서·보안토큰·일회용 비밀번호 등 안전한 인증수단 적용 (이용자가 아닌 정보주체를 처리하는 시스템은 VPN 등 안전한 접속수단도 가능)
③	공개 · 유출 방지 조치	• 인터넷 홈페이지, P2P, 공유설정 등을 통해 권한 없는 자에게 공개·유출되지 않도록 시스템 및 취급자의 컴퓨터·모바일 기기에 조치
④	자동 접속 차단	• 일정 시간 이상 업무처리를 하지 않는 경우 자동으로 접속이 차단되도록 조치
⑤	업무용 모바일 기기 보호	• 분실·도난으로 개인정보가 유출되지 않도록 비밀번호 설정 등 보호조치

- 제5조는 「누구에게 무엇을 허용할 것인가」, 제6조는 「어디에서 어떻게 접속하는가」를 규율

제6조의2 : 인터넷망의 차단 조치

□ 적용 대상

- 전년도 말 기준 직전 3개월간 저장·관리되는 이용자 수가 일일평균 100만명 이상인 개인정보처리자

□ 차단 대상이 되는 개인정보취급자의 컴퓨터 등

1. 개인정보처리시스템에 대한 접근 권한을 설정할 수 있는 개인정보취급자

2. 개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있는 개인정보취급자

□ 예외: 내부 관리계획에서 정한 위험 분석 결과에 따라 인터넷 망을 차단하지 않을 수 있음

- ① 위험 분석 결과 확인된 위험이 현저히 낮은 경우
- ② 위험을 감소시킬 수 있는 보호조치를 적용한 경우 ([별표] 예시 고려)

단, 민감정보 또는 제7조①·②의 암호화 대상 정보를 다운로드·파기할 수 있는 컴퓨터는 예외 적용 불가

위험 감소 보호조치 예시 ([별표])	적용 지점
안전한 인증수단 적용, 다운로드 파일 암호화	다운로드 가능 컴퓨터
다운로드 건수 제한, 다운로드 권한자 최소화	다운로드 가능 컴퓨터
출력 시 마스킹·안심번호 등 표시 제한	다운로드 가능 컴퓨터
파기 권한자 최소화, 파기 시 별도 승인	파기 가능 컴퓨터

제7조 : 개인정보의 암호화

□ 암호화 요구가 나뉘는 세 가지 축

무엇을	어디에	누구의
정보의 종류 (인증정보 · 고유식별정보 · 신용카드/계좌번호 · 생체인식정보)	저장 위치 (내부망 · 인터넷망/DMZ · 취급자 PC · 보조저장매체)	정보주체의 유형 (이용자 / 이용자가 아닌 정보주체)

「이용자」와 「이용자가 아닌 정보주체」의 구분이 요구 수준을 가르는 핵심 기준

항	대상	요구되는 조치
제7조①	비밀번호·생체인식정보 등 인증정보	저장·송수신 시 암호화, 비밀번호는 일방향 암호화
제7조②	이용자의 주민등록번호·여권번호·운전면허번호 ·외국인등록번호·신용카드번호·계좌번호· 생체인식정보	암호화하여 저장
제7조③	이용자가 아닌 정보주체의 고유식별정보	인터넷망·DMZ 저장 시 암호화 / 내부망 저장 시 적용여부 및 적용범위 판단
제7조④	인터넷망 구간으로 송·수신하는 개인정보	암호화하여 송·수신
제7조⑤	취급자의 컴퓨터·모바일 기기·보조저장매체에 저장하는 개인정보	암호화 후 저장
제7조⑥	일정 규모 이상 처리자의 암호 키	키 생성·보관·배포·파기 절차 수립

제7조 ①② : 인증정보와 이용자 개인정보

제7조① 비밀번호, 생체인식정보 등 인증정보를 저장 또는 정보통신망을 통하여 송·수신하는 경우에 안전한 암호 알고리즘으로 암호화하여야 한다. 다만, 비밀번호를 저장하는 경우에는 복호화되지 아니하도록 일방향 암호화하여 저장하여야 한다.

□ 「일방향 암호화」의 의미

- 해시 함수로 변환하여 저장 → 서비스 제공자도 원래 비밀번호를 알 수 없음
- 비밀번호는 「확인」만 하면 되고 「복원」할 필요가 없으므로 암호화가 아니라 해시를 사용
- 무작위 대입 공격·레인보우 테이블 공격에 대응하기 위해 솔트값 추가를 고려해야 함

□ 인증정보 의미

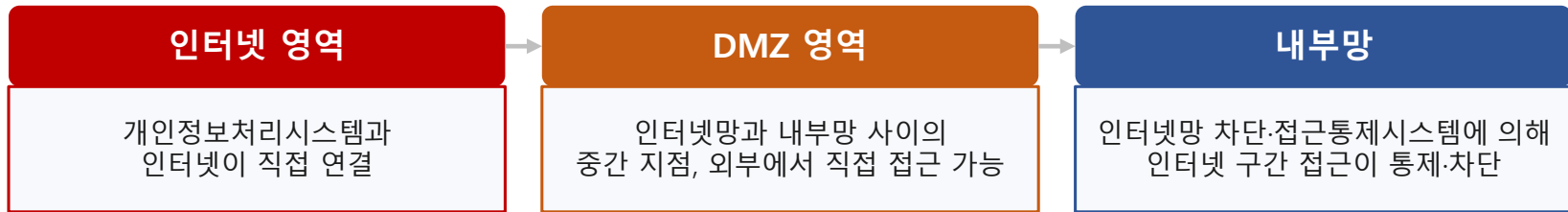
- 접근토큰(Access Token)·갱신토큰·비밀접근키도 인증정보에 해당하면 암호화 대상
- 「정보통신망」은 내부망을 포함하므로 내부망에서 인증정보를 송·수신할 때도 암호화 필요

□ 제7조② : 암호화하여 저장해야 하는 이용자의 개인정보 (7종)

주민등록번호	여권번호	운전면허번호	외국인등록번호
신용카드번호	계좌번호	생체인식정보	

- 앞의 4종은 고유식별정보, 뒤의 3종은 유출 시 직접적인 금전·신체 피해로 이어지는 정보

제7조 ③④⑤ : 저장 위치와 전송 구간



□ 제7조③ : 이용자가 아닌 정보주체의 개인정보 (임직원 · 거래처 담당자 등)

저장 위치	대상	암호화 요구
인터넷망 구간 · DMZ	고유식별정보	암호화 (예외 없음)
내부망	주민등록번호	암호화 (영향평가·위험도 분석과 무관)
내부망	주민등록번호 외 고유식별정보	영향평가 결과 또는 위험도 분석 결과에 따라 결정

□ 제7조④ : 개인정보를 인터넷망 구간으로 송·수신하는 경우 암호화

- 웹·앱 서비스의 TLS 적용, API 통신 암호화, 이메일·파일 전송 시 암호화가 해당
- 전용선을 쓰더라도 인증정보의 송·수신 구간 암호화를 대체할 수 없음

□ 제7조⑤ : 취급자의 컴퓨터 · 모바일 기기 · 보조저장매체에 저장하는 경우

- 이용자의 개인정보, 또는 이용자가 아닌 정보주체의 고유식별정보·생체인식정보가 대상
- 실무 사고의 상당수가 「업무 편의를 위해 로컬에 내려받은 파일」에서 발생

04. 기술적 안전조치

「안전한 암호 알고리즘」이란

- 고시는 「안전한 암호 알고리즘」이라고만 규정 — 구체적 목록은 국내외 전문기관의 권고를 따름

구분	미국 (NIST)	일본 (CRYPTREC)	유럽 (ECRYPT)	국내
일반형 암호 알고리즘	SHA-224 / 256 / 384 / 512	SHA-256 / 384 / 512	SHA-224 / 256 / 384 / 512, Whirlpool	SHA-224 / 256 / 384 / 512
대칭키 암호 알고리즘	AES-128 / 192 / 256	AES, Camellia -128 / 192 / 256	AES, Camellia, Serpent	SEED, HIGHT, ARIA, LEA
공개키 암호 알고리즘	RSA (권고 키 길이 확인)	RSAES-OAEP	RSAES-OAEP	RSAES (키 길이 2048비트 이상)

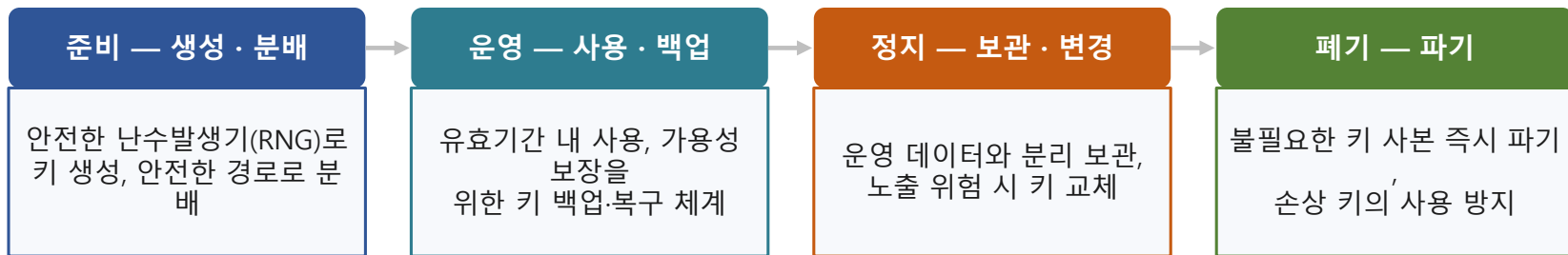
TDEA(3DES), MD5, SHA-1 등 보안 강도가 낮은 것으로 판명된 알고리즘을 사용하여서는 안 됨
 ※ 출처 : 개인정보의 안전성 확보조치 기준 안내서 (개인정보보호위원회)

- 처리속도 등 기술 발전에 따라 권고 알고리즘은 달라지므로 적용 시 최신 정보 확인이 필요
- 클라우드 서비스가 제공하는 암호화 기능을 이용할 수 있으나 이 기준에 부합하는지 확인해야 함

제7조⑥ : 암호 키 관리

10만명 이상의 정보주체를 처리하는 대기업·중견기업·공공기관 또는
100만명 이상의 정보주체를 처리하는 중소기업·단체는
안전한 암호 키 생성, 이용, 보관, 배포 및 파기 등에 관한 절차를 수립·시행하여야 한다.

□ 암호 키의 생애주기 (Key Lifecycle)



□ 키 관리에서 반드시 지켜야 할 사항

- ① 암호 키는 암호화된 데이터와 분리하여 보관하고, 사본은 물리적으로 분리된 곳에 보관
- ② 응용프로그램 소스 프로그램 내에 평문으로 저장 금지 (하드코딩 금지)
- ③ 키 접근 권한도 최소화하고 접근 이력을 기록
- ④ 키 분실은 데이터의 영구 소실을 의미 → 키 관리는 「가용성」 문제이기도 함
- ⑤ 노출 위험이 있거나 유효기간 만료가 가까우면 키를 안전하게 교체 (Key Rotation)

제8조 : 접속기록의 보관 및 점검

□ 보관 기간 (제8조①)

구분	보관 기간
일반적인 경우	1년 이상
① 5만명 이상의 정보주체에 관한 개인정보를 처리하는 시스템 ② 고유식별정보 또는 민감정보를 처리하는 시스템 ③ 「전기통신사업법」상 기간통신사업자에 해당하는 경우	2년 이상

□ 접속기록에 포함되어야 할 항목 (제2조 정의)

- 식별자(계정)/접속일시/접속지 정보(IP 주소)/처리한 정보주체의 정보/수행 업무
 - 로그인·로그아웃·로그인 실패 정보도 접속기록으로 보관 (이 경우 정보주체 정보는 생략 가능)
 - 이용자의 접속기록은 이 기준의 대상이 아니나 「통신비밀보호법」에 따라 3개월 이상 보관

□ 점검 (제8조②)

- 오·남용, 분실·도난·유출·위조·변조·훼손에 대응하기 위해 접속기록과 다운로드 상황을 확인·점검
- 점검 주기 · 방법 · 사후조치절차를 내부 관리계획으로 정하고 이행해야 함

□ 보호 (제8조③)

- 접속기록이 위·변조 및 도난, 분실되지 않도록 안전하게 보관하기 위한 조치를 해야 함
- 로그 서버 분리, 쓰기 전용 저장, 로그 해시·서명, 접근권한 제한 등이 실무 수단

접속기록 점검과 이상행위 탐지

□ 무엇을 이상행위로 볼 것인가

탐지 관점	이상 징후 예시	대응
양(Volume)	평소보다 현저히 많은 건수의 조회·다운로드	건수 임계값 설정, 초과 시 경보·차단
시간(Time)	업무 시간 외·휴일의 대량 접속	시간대별 접속 정책, 사유 소명 요구
위치(Place)	등록되지 않은 IP·국외에서의 접속	IP 기반 접속 제한, 접속 위치 알림
대상(Target)	업무와 무관한 정보주체의 정보 반복 조회	업무 연관성 점검, 조회 사유 입력 의무화
행위(Action)	권한 변경 직후의 대량 조회, 파기 권한 사용	권한 변경 이력과 접속기록의 교차 점검

□ 점검 체계를 갖출 때의 고려 사항

- ① 점검 주기 : 규모와 위험도에 따라 자체 결정하되 내부 관리계획에 명시
- ② 점검 방법 : 표본 점검 · 자동화 분석 · 임계값 기반 경보 등을 조합
- ③ 사후조치 : 소명 요구 → 조사 → 권한 조정 · 징계 · 신고까지의 절차를 사전에 정의

점검의 최종 책임은 개인정보 보호책임자에게 있으며, 보고 주기도 내부 관리계획에서 정함

제9조 : 악성프로그램 등 방지

□ 보안 프로그램의 설치·운영 (제9조①)

- 악성프로그램 등을 방지·치료할 수 있는 보안 프로그램을 설치·운영해야 함

① 자동 업데이트 기능을 사용하거나, 정당한 사유가 없는 한 일 1회 이상 업데이트하여 최신 상태 유지

② 발견된 악성프로그램 등에 대해 삭제 등 대응 조치

□ 보안 업데이트의 즉시 적용 (제9조②)

- 악성프로그램 관련 경보 발령, 또는 응용프로그램·운영체제 제작업체의 보안 업데이트 공지가 있는 경우
- 정당한 사유가 없는 한 즉시 업데이트 실시

실제 사고에서 반복되는 패턴	결과
취급자 PC의 악성코드 감염 → 내부망 침투 → 계정 탈취	대규모 DB 유출
알려진 취약점의 보안 패치 미적용	공개된 공격 도구로 손쉽게 침해
보안 프로그램 설치는 되어 있으나 업데이트 중단	신종 악성코드 탐지 실패
서버·네트워크 장비의 기본 계정·기본 설정 유지	초기 침투 경로 제공

「알려진 취약점을 방치한 침해」는 안전조치 의무 미이행으로 평가될 가능성이 높음
— 공격 기법의 정교함보다 기본 관리의 공백이 사고의 주된 원인

제10~12조 : 물리적 안전조치

제10조 물리적 안전조치

- ① 전산실·자료보관실 등 물리적 보관 장소를 별도로 두는 경우 출입통제 절차 수립·운영
- ② 개인정보가 포함된 서류·보조저장매체를 잠금장치가 있는 안전한 장소에 보관
- ③ 보조저장매체의 반출·입 통제를 위한 보안대책 마련
(별도 시스템 없이 업무용 컴퓨터·모바일 기기만으로 처리하는 경우 미적용 가능)

제11조 재해·재난 대비

- 10만명 이상 처리 대기업·중견기업·공공기관 또는 100만명 이상 처리 중소기업·단체 대상
- ① 화재·홍수·단전 등에 대비한 위기대응 매뉴얼 등 대응절차 마련 및 정기 점검
 - ② 개인정보처리시스템 백업 및 복구를 위한 계획 마련 (대상·방법·절차 포함)

제12조 출력·복사시 안전조치

- ① 출력 시(인쇄, 화면표시, 파일생성 등) 용도를 특정하고, 용도에 따라 출력 항목을 최소화
 - ② 종이 인쇄물·외부 저장매체 등 출력·복사물을 안전하게 관리하기 위한 조치
- 「출력」은 종이 인쇄만이 아니라 화면표시·파일생성까지 포함 — 다운로드도 출력에 해당**

규모 · 유형에 따른 의무의 차등

기준	해당 의무	근거
1만명 미만 정보주체를 처리하는 소상공인·개인·단체	내부 관리계획 수립·시행을 생략할 수 있음 (그 외 안전조치 의무는 모두 이행)	제4조① 단서
5만명 이상 처리 시스템 / 고유식별·민감정보 처리 시스템 / 기간통신사업자	접속기록을 2년 이상 보관·관리	제8조①
10만명 이상 처리 대기업·중견기업·공공기관 또는 100만명 이상 처리 중소기업·단체	- 암호 키 생성·이용·보관·배포·파기 절차 수립·시행 - 재해·재난 대비 위기대응 매뉴얼 마련 및 정기 점검 - 시스템 백업 및 복구 계획 마련	제7조⑥ 제11조
일일평균 이용자 수 100만명 이상 개인정보처리자	인터넷망 차단 조치 (권한 설정 가능자, 다운로드·파기 가능자의 컴퓨터 등)	제6조의2
공공시스템운영기관	내부 관리계획·접근 권한·접속기록에 관한 강화된 특례 적용	제14~17조

- 「우리 조직에 어떤 의무가 적용되는가」는 처리하는 정보주체 수와 기업 규모를 먼저 산정해야 판단 가능

제14~17조 : 공공시스템운영기관 특례

- 일정 요건에 해당하는 공공시스템을 운영하는 기관에 추가로 적용되는 강화 규정
- 다수 기관이 공동 이용하고 대량의 개인정보를 다루는 시스템의 특수성을 반영

제15조 내부 관리계획

- 공공시스템별로 안전조치에 관한 사항을 포함하여 수립
- 관리책임자 지정 등 관리 체계 명확화

제16조 접근 권한 관리

- 인사정보에 등록되지 않은 자에게 계정 발급 금지 (긴급 시 사유 기록)
- 계정 발급 시 개인정보 보호 교육 실시 및 보안 서약 징구
- 접근 권한 부여·변경·말소 내역을 반기별 1회 이상 점검
- 이용기관이 직접 권한을 관리하는 경우에도 동일 조치 적용

제17조 접속기록

- 접속기록 등을 자동화된 방식으로 분석하여 불법적 유출 및 오·남용 시도를 탐지하고 그 사유를 소명하도록 하는 등 필요한 조치
- 이용기관이 소관 취급자의 접속기록을 직접 점검할 수 있는 기능 제공

- 특례의 방향 :
① 계정 발급의 엄격화 ② 권한 점검의 정례화 ③ 접속기록 분석의 자동화

안전조치 의무 미이행 시의 제재

과징금	개인정보가 분실·도난·유출·위조·변조·훼손된 경우 전체 매출액의 100분의 3을 초과하지 아니하는 범위에서 부과 (다만 안전성 확보에 필요한 조치를 다한 경우에는 제외)
과태료	안전성 확보에 필요한 조치를 하지 아니한 경우 3천만원 이하의 과태료 (법 제75조②)
시정명령 · 공표	위반사항에 대한 시정조치 명령, 위반 사실의 공표 및 처분 내용의 공개
민사 · 형사 책임	손해배상(법정손해배상·징벌적 손해배상 포함), 관련 행위에 대한 형사 처벌 및 양벌규정

- 「사고가 나지 않았더라도」 안전조치를 하지 않은 사실 자체가 제재 사유가 될 수 있음
 - 반대로 요구되는 조치를 충실히 이행한 기록(점검·교육·권한·접속기록)은 책임 경감의 근거가 됨

사고에서 드러나는 미이행 지점

사고 유형	드러난 미이행 지점	관련 조문
취급자 PC 감염 후 내부망 침투	보안 프로그램 미갱신, 보안 패치 미적용, 내외부망 분리 미흡	제9조 제6조의2
내부자의 대량 다운로드 후 반출	과도한 권한 부여, 다운로드 통제 부재, 접속기록 점검 미실시	제5조 제8조
평문 DB 유출	암호화 대상 정보 미암호화, 암호 키를 데이터와 동일 위치에 보관	제7조
퇴사자 계정을 통한 무단 접근	권한 말소 지연, 계정 공유, 권한 이력 미보관	제5조
수탁자 측에서의 유출	위탁 계약의 안전조치 조항 미흡, 실질적 관리·감독 부재	법 제26조 제4조
취약 해시로 저장된 비밀번호 복원	안전성이 깨진 알고리즘 사용, 솔트 미적용	제7조①

사고의 원인은 대부분 「새로운 공격 기법」이 아니라 「이미 규정된 조치의 미이행」
→ 기준을 이해하는 것 자체가 가장 효율적인 보안 활동

안전조치와 암호기술의 연결

조문	요구되는 상태	적용되는 암호기술
제5조·제6조 인증수단	접속자가 본인임을 확인	해시·솔트 기반 비밀번호 저장, OTP, 인증서, 다중 인증
제7조① 비밀번호	복호화 불가능한 저장	일방향 해시 + 솔트 + 키 스트레칭
제7조②③⑤ 저장 암호화	유출되어도 판독 불가	대칭키 암호(AES 등), 블록암호 운영모드, 컬럼·파일·디스크 암호화
제7조④ 전송 암호화	전송 중 도청·변조 방지	TLS (공개키 기반 키 교환 + 대칭키 통신)
제7조⑥ 키 관리	키의 안전한 생성·보관·파기	난수 생성, 키 분배·교환, 키 파기
제8조③ 접속기록 보호	로그의 위·변조 방지	해시 함수, 메시지 인증 코드, 전자서명
제13조 파기	복구 불가능한 삭제	암호키 파기 (크립토 셰딩)

- 법이 요구하는 「상태」를 만들어 내는 수단이 곧 암호기술

05. 물리적 안전조치와 이행 관리

이행 점검 체크리스트

관리

- 내부 관리계획을 수립하고 최고경영층의 승인을 받았는가
- 취급자 교육을 정기적으로 실시하고 결과를 기록했는가
- 보호책임자가 이행 실태를 연 1회 이상 점검했는가
- 수탁자에 대한 관리·감독을 실질적으로 수행했는가

기술

- 접근 권한을 최소 범위로 차등 부여하고 이력을 3년간 보관하는가
- 취급자별 계정을 발급하고 계정 공유를 금지했는가
- 암호화 대상 정보를 모두 식별하고 암호화를 적용했는가
- 암호 키를 데이터와 분리 보관하고 키 관리 절차가 있는가
- 접속기록을 규정 기간 보관하고 정기적으로 점검하는가
- 보안 프로그램을 최신 상태로 유지하고 패치를 즉시 적용하는가

물리

- 전산실·자료보관실의 출입통제 절차가 있는가
- 서류·보조저장매체를 잠금장치가 있는 장소에 보관하는가
- 출력물의 용도를 특정하고 항목을 최소화하는가

핵심 정리 (1)

개인정보 생명주기

수집 → 저장·관리 → 이용·제공 → 파기의 네 단계, 단계마다 위협과 보호조치가 다름
수집 단계의 최소화가 이후 전 단계의 위협과 보호 비용을 결정
이용·제공 단계는 「정당한 권한을 가진 사람」이 위협 주체 → 기록·탐지 중심 통제

기준의 법적 위치

법 제29조(안전조치의무) → 시행령 제16조②·제30조·제30조의2 → 고시 → 안내서
적용 대상은 개인정보처리자·제공받은 자·수탁자, 성격은 「최소한의 기준」
핵심 용어(개인정보처리시스템·접속기록·내부망·인증정보)는 제2조가 정의

적용 원칙 (제3조)

보유 수 · 유형 · 정보주체에게 미치는 영향을 고려한 「위험 비례」 적용
스스로 판단하되 판단 근거(위험도 분석·내부 관리계획)를 문서로 입증해야 함

관리적 안전조치

제4조 내부 관리계획 : 18개 항목, 최고경영층 승인, 정기 교육, 연 1회 이상 이행 실태 점검
내부 관리계획(내부·비공개) vs 처리방침(외부·공개) — 근거·목적·독자가 모두 다름
위험도 분석은 내부망 고유식별정보 암호화 여부 판단의 근거

핵심 정리 (2)

접근 통제 계열

제5조 : 최소 권한 차등 부여, 지체 없는 변경·말소, 권한 이력 3년 보관, 취급자별 계정, 인증 실패 시 제한
 제6조 : IP 기반 접속 제한과 유출 시도 탐지, 외부 접속 시 안전한 인증수단, 자동 접속 차단
 제6조의2 : 일일평균 이용자 100만명 이상 → 권한 설정·다운로드·파기 가능자 컴퓨터의 인터넷망 차단

암호화 (제7조)

- ① 인증정보는 저장·송수신 시 암호화, 비밀번호는 일방향 암호화 (솔트 고려)
- ② 이용자의 주민등록·여권·운전면허·외국인등록·신용카드·계좌번호·생체인식정보는 암호화 저장
- ③④⑤ 저장 위치(인터넷망/DMZ·내부망·취급자 기기)와 전송 구간에 따라 요구 수준이 달라짐
- ⑥ 일정 규모 이상 처리자는 키 생성·보관·배포·파기 절차 수립, 키는 데이터와 분리 보관

기록과 방지

제8조 : 접속기록 1년 이상 보관(5만명 이상·고유식별/민감정보·기간통신사업자는 2년 이상),
 점검 주기·방법·사후조치를 내부 관리계획으로 정하고 이행, 접속기록 위·변조 방지
 제9조 : 보안 프로그램 최신 유지(일 1회 이상), 보안 업데이트 공지 시 즉시 적용

물리 · 이행 관리

제10~12조 : 출입통제, 매체 잠금 보관·반출입 통제, 재해·재난 대비, 출력 용도 특정·항목 최소화
 제13조 : 완전 파괴 / 전용 소자장비 / 초기화·덮어쓰기, 일부 파기 시 마스크·천공
 제재 : 유출 시 전체 매출액의 3% 이하 과징금, 조치 미이행 시 3천만원 이하 과태료



Thank You

E-mail: seyoung@kangwon.ac.kr